

Creating a Machine-Readable SKOS Taxonomy of the NIST Cybersecurity Framework 2.0

GHEORGHE TURCA, University of Twente, The Netherlands

The NIST Cybersecurity Framework (CSF) 2.0 is a widely used framework for managing cybersecurity risk. It organizes cybersecurity outcomes into a structured Core of Functions, Categories, and Subcategories, helping organizations understand, assess, prioritize, and communicate their cybersecurity efforts [1]. Although NIST provides official documents, reference tools, and structured exports, the CSF 2.0 Core is not currently available as a validated semantic taxonomy. As a result, framework elements cannot be directly queried through standard Semantic Web technologies, structurally validated as RDF data, or semantically linked to related cybersecurity standards such as ISO/IEC 27001 without additional interpretation.

This research proposes the development of a Simple Knowledge Organization System (SKOS) taxonomy of the NIST CSF 2.0. The taxonomy will be represented using Resource Description Framework (RDF), a standard for modeling and interlinking data on the web using a graph-based structure composed of subject-predicate-object triples [6]. Functional validation will be performed through competency questions, which are natural-language questions used to define what the taxonomy should be able to answer [9]. These questions will be translated into SPARQL queries, the standard query language for RDF data [7]. Structural validation will be carried out using SHACL shapes, which are constraints for checking the consistency and completeness of RDF data [8]. In addition, this research will investigate how the NIST CSF 2.0 taxonomy can be linked to an existing ISO/IEC 27001 SKOS taxonomy to enable cross-standard navigation between them.

Additional Key Words and Phrases: NIST Cybersecurity Framework 2.0, SKOS, RDF, Taxonomy, SPARQL, SHACL.

1 Introduction

The NIST Cybersecurity Framework (CSF) 2.0 is a widely used framework for managing cybersecurity risk. It organizes cybersecurity outcomes into a structured Core consisting of six high-level Functions: Govern, Identify, Protect, Detect, Respond, and Recover [1]. These Functions are further divided into Categories and Subcategories, which describe more specific cybersecurity outcomes. The framework is intended to help organizations understand, assess, prioritize, and communicate cybersecurity risks and activities. Because many organizations also work with other cybersecurity standards, such as ISO/IEC 27001, there is practical value in representing the CSF in a form that supports structured access, querying, validation, and cross-standard navigation.

Although the NIST CSF 2.0 has a clear internal structure, it is not currently available as a validated SKOS taxonomy. NIST provides official documents, the CSF 2.0 Reference Tool, and structured exports such as Excel [2, 3]. These resources support human use and basic

data reuse, but they do not provide a standardized semantic representation using RDF and SKOS. As a result, retrieving framework elements according to their hierarchy, checking whether the representation is structurally complete, querying practitioner-oriented questions, or linking CSF outcomes to related ISO/IEC 27001 concepts still need additional interpretation. For example, a practitioner could query the taxonomy to retrieve all NIST CSF Subcategories related to access control, inspect their definitions and implementation examples, and follow links to related ISO/IEC 27001 controls. A researcher could also use the same RDF graph to check the CSF hierarchy, count reference links, or reuse stable concept URIs in another cybersecurity tool. These tasks are difficult to support directly from PDF-based framework documentation.

This research addresses the following main research question:

RQ: How can the NIST Cybersecurity Framework 2.0 be represented as a SKOS taxonomy to enable structured, machine-readable access, validation, and cross-standard linking?

This main question is answered through the following sub-research questions:

- **SRQ1:** Which structural elements, relationships, and selected external references of the NIST CSF 2.0 should be represented in the SKOS taxonomy?
- **SRQ2:** Does the resulting SKOS taxonomy provide correct answers to competency questions when queried with SPARQL?
- **SRQ3:** How can the NIST CSF 2.0 taxonomy be linked to the existing ISO/IEC 27001 SKOS taxonomy to support cross-standard navigation?

To answer these questions, the NIST CSF 2.0 Core was extracted from official NIST and then encoded as RDF using SKOS. The taxonomy was serialized in Turtle format and validated structurally using SHACL shapes and additional SPARQL checks. Functional validation was performed using competency questions translated into SPARQL queries. In addition, selected ISO/IEC 27001 references were linked to an existing ISO/IEC 27001 SKOS taxonomy to support cross-standard navigation. A local browser was also implemented to support manual exploration of the taxonomy and its links.

2 Related Work

Research on machine-readable representations of cybersecurity standards has often focused on ontology-based modeling. NIST has already taken steps at the official level toward structured access to the cybersecurity framework content. The NIST CSF 2.0 Reference Tool allows users to explore the CSF Core and export framework content in machine-readable formats such as JSON and Excel [2, 3]. In addition, the Cybersecurity and Privacy Reference Tool (CPRT) and the National Online Informative References (OLIR) program support structured reuse of NIST reference data and relationships

Author's Contact Information: Gheorghe Turca, g.turca@student.utwente.nl, University of Twente, Enschede, The Netherlands.

TScIT 45, Enschede, The Netherlands

© 2026 ACM.

This is the author's version of the work. It is posted here for your personal use. Not for redistribution. The definitive Version of Record was published in *Proceedings of 45th Twente Student Conference on IT (TScIT 45)*, <https://doi.org/10.1145/nnnnnnn.nnnnnnn>.

between cybersecurity documents [14, 15]. However, these do not provide a general-purpose SKOS taxonomy of the NIST CSF 2.0.

Several studies also used the NIST CSF as a basis for semantic modeling, compliance assessment, and ontology-based reasoning. A generic model for dynamic NIST CSF compliance assessment has been proposed to support compliance measurement, cybersecurity risk estimation, and resource allocation [16]. Ontology-based work has also been applied to cybersecurity operations centre analysis processes aligned with the NIST CSF [17]. More recent graph-based work maps cloud security controls to the NIST Cybersecurity Framework to support cloud security compliance [18]. These works show that the NIST CSF has been used as a semantic reference point, but they mainly focus on compliance or mappings from other control systems to NIST CSF rather than on representing the CSF Core itself as a SKOS taxonomy.

Other work compared NIST CSF with ISO/IEC 27001 more directly. A semantic analysis of the ISO/IEC 27000 series and the NIST CSF has been used to identify differences and consistencies in operational and strategic information security [19]. The study is based on CSF 1.0, but it is still relevant because it shows the compatibility between them and argues that both can be used together in practice.

Recent preprint work has also proposed ontology-based modeling around NIST CSF 2.0. RiskOnto 1.0 is presented as an OWL-based ontology-driven framework for threat modeling and risk reasoning using NIST CSF 2.0, NIST SP 800-53, and MITRE D3FEND [20]. The framework models cybersecurity entities such as threats, vulnerabilities, risks, controls, functions, and uses semantic relationships and SWRL rules to support automated reasoning. This work is relevant because it shows recent interest in formal semantic representations of NIST CSF 2.0. However, its focus is risk reasoning, while the present research focuses on creating a SKOS taxonomy for NIST CSF 2.0.

Research on other cybersecurity standards provides useful methodological guidance. Earlier work on ISO/IEC 27001 used OWL ontologies to support audit preparation, information security knowledge formalization, and compliance determination [10–12]. However, comparative research on ISO 27000-series ontologies identified limitations such as structural rigidity, incomplete coverage, and weak reproducibility [13]. These limitations motivate the use of a simpler vocabulary-based representation such as SKOS. The closest prior work is a SKOS taxonomy of ISO/IEC 27001:2022, which represents ISO/IEC 27001 clauses, Annex A controls, ISO/IEC 27002 guidance, and ISO/IEC 27000 vocabulary terms as a queryable RDF/SKOS artifact validated through competency questions and SPARQL queries [4]. This proposal follows a similar methodological direction, but applies it to the NIST Cybersecurity Framework 2.0 and extends the focus toward linking the resulting NIST CSF taxonomy to the existing ISO/IEC 27001 SKOS taxonomy.

Overall, existing research shows that the NIST CSF has been used in semantic models, ontologies, compliance tools, and knowledge graphs. However, these works either focus on domain-specific reasoning, compliance assessment, or mappings from other control systems to the NIST CSF. What remains missing is a validated, general-purpose RDF/SKOS taxonomy of the NIST CSF 2.0 Core itself, supporting structured, external references, structural validation, and cross-standard linking.

3 Methodology

This research follows a reproducible methodology to transform the NIST Cybersecurity Framework (CSF) 2.0 Core into a machine-readable SKOS taxonomy, validate its internal structure, and connect it to an existing ISO/IEC 27001 SKOS taxonomy [1, 4, 5]. The methodology was designed to answer the main research question by constructing the taxonomy, validating its structure, testing whether it supports practitioner-oriented retrieval tasks, and evaluating whether it can be linked to an existing ISO/IEC 27001 SKOS taxonomy. The approach combined four main stages: selecting and constraining the source material; preprocessing and normalizing the extracted content; generating the RDF/SKOS artifact through a Python pipeline; and validating the resulting graph through SHACL, structural SPARQL checks, and dedicated mapping checks [6–8].

The methodology is organized around the three sub-research questions. SRQ1 is addressed by extracting the CSF Core structure and encoding it as a SKOS taxonomy while preserving the Function–Category–Subcategory hierarchy. SRQ2 is addressed by evaluating whether the taxonomy can answer a defined set of competency questions translated into executable SPARQL queries. SRQ3 is addressed by modeling selected informative references as local reference concepts and linking those concepts to the existing ISO/IEC 27001 SKOS taxonomy where a corresponding ISO concept exists.

3.1 Choice of Semantic Web Technologies

The goal of this research is not to store the NIST CSF 2.0 Core in a structured file, but to represent it as a machine-readable knowledge structure that can be queried, validated, and linked to other cybersecurity standards. The source framework already has a clear conceptual organization: Functions contain Categories, Categories contain Subcategories, and Subcategories contain descriptions, implementation examples, and informative references which makes it suitable for representation as a graph, where each framework element can be modeled as a resource and where relationships can be explicitly represented.

RDF was selected as the data model because it represents information as subject–predicate–object triples [6]. This is appropriate for the NIST CSF 2.0 because each framework element can be described through statements such as: a Subcategory has a notation, a Category has a preferred label, a Subcategory has a broader Category, and a NIST concept references an external standard. Representing the framework as RDF also makes the taxonomy interoperable with other RDF-based vocabularies.

SKOS was selected as the main modeling vocabulary because the NIST CSF 2.0 Core is primarily a taxonomy of cybersecurity outcomes rather than a rule-based ontology. SKOS provides standard properties for the elements needed in this research, including `skos:Concept` for framework elements, `skos:prefLabel` for labels, `skos:definition` for descriptions, `skos:notation` for identifiers, and `skos:broader` and `skos:narrower` for hierarchical relations [5]. This matches the structure of the CSF Core, where Functions, Categories, and Subcategories are organized in a hierarchy.

OWL was not a choice because the objective of this research is not to define complex logical axioms or perform automated reasoning over cybersecurity rules. OWL is more expressive than SKOS,

but that expressiveness also introduces additional modeling complexity. For example, an OWL ontology would require decisions about classes, individuals, object properties, restrictions, and inference behavior. These features are useful when the goal is logical reasoning, but they are not necessary for representing the NIST Core. Using OWL for this project would therefore make the model more complex and harder to maintain if any changes happen.

SPARQL was used for query-based validation, while SHACL was used for structural validation. SPARQL, the standard query language for RDF data, was used to translate competency questions into executable queries and to perform additional quality checks, such as detecting missing English labels or duplicate notations [7]. SHACL was used because RDF does not enforce constraints by itself. The SHACL shapes check whether the taxonomy preserves the expected CSF hierarchy, contains required data, and uses reference and mapping links consistently [8].

3.2 Data Extraction and Scope

The main source for the taxonomy is the NIST CSF 2.0 Core [1]. The extraction was limited to the Core. Other parts of the CSF 2.0, such as Profiles and Tiers, were not included in the implemented taxonomy. This decision was partly made because of the limited time available for the project and because the initial focus was placed on the stable structure of the Core. At the start of the research, Profiles and Tiers were considered less central to the main taxonomy artifact; however, during the development of the competency questions, it became clear that Profiles could also be useful for practitioner-oriented queries, for example, questions about how an organization could compare a current cybersecurity state with a target state. For that reason, the inclusion of Profiles was mentioned as future work rather than as part of the implementation.

For the extraction, instead of using the official NIST CSF 2.0 PDF, the implementation used the spreadsheet exports from the NIST CSF 2.0 Reference Tool [2, 3]. The reason for this was that spreadsheets provide the Core in a tabular format and have the complete information as the PDF but require less formatting; also, the informative reference spreadsheets offer translation in multiple languages, which we used as well to have a multilingual taxonomy, even though they were incomplete, by missing the implementation examples.

First, the spreadsheet exports were parsed with a Python script and converted into an intermediate CSV file. Technically, the spreadsheets could have been converted directly into RDF, but separating extraction from RDF/SKOS generation made later changes easier to apply and kept the code less confusing by dividing it into separate scripts. The columns registered in the CSV were `id`, `parent_id`, `type`, `implementation_examples`, `informative_references`, `label_en`, and `description_en`. For each additional language, the corresponding label and description were also stored in separate language-specific columns. The main missing information in the translated spreadsheets was the implementation examples, which were only available in English, even in the official NIST CSF 2.0.

A specific extraction decision which was also taken was for Subcategory labels. Functions and Categories in the spreadsheet include both an identifier and a short textual label, such as GV for *Govern*

or GV.OC for *Organizational Context*. Subcategories, however, are mainly presented through their identifier and a full outcome statement. Initially, the outcome statement was considered as the label, but this made labels too long for browsing, query results, and hierarchy visualization. Therefore, the Subcategory identifier, such as GV.OC-01, was used as the label, while the full outcome statement was stored separately as the description.

The parser identifies the type of each CSF element from the notation pattern used in the spreadsheet. Function identifiers, such as GV, are treated as top-level concepts. Category identifiers, such as GV.OC, are treated as children of Functions. Subcategory identifiers, such as GV.OC-01, are treated as children of Categories. While reading the spreadsheet, the parser keeps track of the current Function and Category in order to assign the correct parent identifier to each element. This parent identifier is later used to generate the SKOS hierarchy.

The English NIST CSF 2.0 export was used as the structural reference because it contains the complete Core structure and the most complete Informative Reference information. The multilingual exports were then processed to add translated labels and descriptions to the same set of concepts. In the intermediate CSV, these values are stored in language-specific columns, such as English, French, German, Spanish, and other available translations. In the RDF graph, these values are later represented as language-tagged literals. Implementation examples and Informative References were kept from the English export, since these fields were not equally complete in all language files.

The extraction process also handles withdrawn CSF elements. The official spreadsheet includes older withdrawn Categories and Subcategories, but these were not included in the implemented taxonomy. The parser detects withdrawn elements and keeps only the active CSF Core concepts. This decision was made because many withdrawn elements were reorganized and moved to other parts of the current framework since CSF 2.0 added the GOVERN function, which was missing in CSF 1.1. Including them would therefore mix current and deprecated framework elements.

Informative References were extracted as reference strings and represented as local reference concepts. To support this, a separate extraction step was created to collect the unique Informative References from the intermediate CSV into a reference-link CSV file. This file was used as a supporting lookup table during RDF generation. Each reference was represented as a local `skos:Concept`, allowing it to have its own notation, label, external link where available, and possible mapping to another taxonomy. External links were treated as optional enrichment rather than as the main focus of the research. Where a reference corresponded to a concept in the existing ISO/IEC 27001 SKOS taxonomy, it was connected during RDF generation using a mapping link.

3.3 RDF/SKOS Modeling

After data extraction, the cleaned CSF Core CSV and the Informative Reference CSV were used as input for RDF/SKOS generation. This step was implemented with a Python script using `rdflib`. The script reads the CSV files, creates an RDF graph, binds the required namespaces, creates the SKOS concepts and relationships, and serializes

the final graph as a Turtle file (.ttl). Automated generation was chosen instead of manually writing the taxonomy because the CSF Core contains many concepts, multilingual labels, implementation examples, and Informative References. Manual modeling would be difficult to reproduce and would require repeating the same task for each NIST CSF outcome, increasing the risk of inconsistent identifiers, missing hierarchy links, or incomplete reference links.

Each Function, Category, and Subcategory is represented as a `skos:Concept`. This was chosen because these elements are not treated as classes but as entries. For example, `GV`, `GV.OC`, and `GV.OC-01` are framework concepts that need labels, definitions, identifiers, and hierarchical relations. The concept is assigned to the Core concept scheme using `skos:inScheme`. This makes explicit that each Function, Category, and Subcategory belongs to the NIST CSF 2.0 Core taxonomy. The original NIST identifier is represented using `skos:notation` because identifiers such as `GV.OC-01` are codes used by the framework rather than natural-language labels. Labels are therefore kept separately as `skos:prefLabel`, while the notation preserves the official CSF identifier in a queryable form.

The level of each CSF concept is written using `dcterms:type`, with values such as Function, Category, and Subcategory. This allows the taxonomy to distinguish between the three CSF levels while still representing all of them as `skos:Concepts`. Separate RDF classes were not created for each level because the Function–Category–Subcategory structure is already represented through the SKOS hierarchy. Using `dcterms:type` therefore keeps the model simple and still supports SPARQL queries that need to retrieve only Functions, only Categories, or only Subcategories.

The labels and descriptions from the CSV are added as multilingual RDF literals. Labels are represented using `skos:prefLabel`, and descriptions are represented using `skos:definition`. The language code from each CSV column is preserved as a language tag in RDF. For example, English labels are stored with the `@en` language tag, French labels with `@fr`, German labels with `@de`, and so on. This allows the same concept URI to have labels and definitions in multiple languages while preserving one shared CSF hierarchy. Implementation examples are represented using `skos:example`. Since the implementation examples were only consistently available in English, they are added as English literals.

The hierarchy of the CSF Core is generated from the `parent_id` column in the intermediate CSV. Functions have no parent and are therefore modeled as top concepts of the Core concept scheme. They are connected to the scheme using `skos:hasTopConcept`, and the inverse relation from each Function to the scheme is represented using `skos:topConceptOf`. Categories are connected to their parent Functions using `skos:broader`, and Functions are connected back to their Categories using `skos:narrower`. The same pattern is used between Subcategories and Categories.

For example, a Function such as `GV` is represented as a top concept of the Core scheme. A Category such as `GV.OC` is represented as a narrower concept of `GV` and has `GV` as its broader concept. A Subcategory such as `GV.OC-01` is represented as a narrower concept of `GV.OC` and has `GV.OC` as its broader concept. Also, in the generated URI structure, dots are normalized into hyphens, so `GV.OC-01` becomes a local URI such as `https://example.org/nist-csf-2.0/concept/GV-OC-01`. This URI normalization was necessary

because CSF identifiers and reference strings can contain dots or other characters that are not suitable for stable URI fragments.

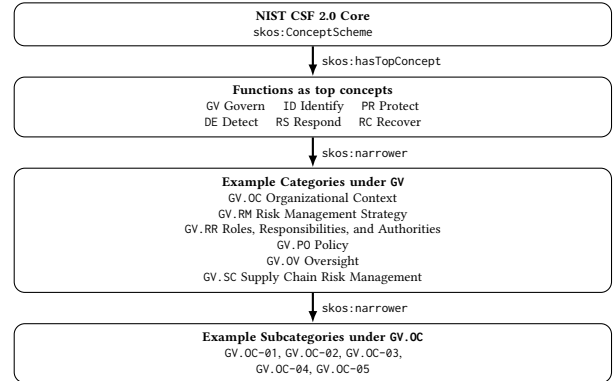


Fig. 1. Simplified NIST CSF 2.0 Core hierarchy in the generated SKOS taxonomy.

Informative References are not stored as plain text notes on CSF concepts. Instead, they are modeled as separate local `skos:Concepts` in the Informative Reference concept scheme. This design was chosen because references need to be queryable and enrichable as resources. If they were stored only as text, they could not easily have their own notation, label, external link, or mapping to another taxonomy. Each reference concept is assigned `rdf:type skos:Concept`, added to the reference scheme using `skos:inScheme`, given the type `InformativeReference` using `dcterms:type`, assigned a reference string using `skos:notation`, and assigned an English label using `skos:prefLabel`.

The link from a CSF Core concept to an informative reference concept is represented using `dcterms:references`. This relation was chosen instead of `skos:exactMatch` because an informative reference is not the same concept as the CSF outcome that mentions it. For example, a CSF Subcategory may refer to an ISO/IEC 27001 clause or control as supporting guidance, but the Subcategory itself is not equivalent to that clause or control. Using `skos:exactMatch` at this point would suggest that the NIST concept and the external reference have the same meaning, which is not correct. `dcterms:references` is more appropriate because it only states that the CSF concept cites the reference. In addition, `skos:related` is added in both directions to support bidirectional browsing in the interface, while `dcterms:references` remains the main semantic relation. When an external webpage is available for a reference, it is added using `rdfs:seeAlso`, allowing the taxonomy to point to relevant external documentation without recreating the full content of the referenced standard. This reference model also prepares the taxonomy for cross-standard linking, because local informative reference concepts can later be connected to matching concepts in the existing ISO/IEC 27001 SKOS taxonomy. The detailed modeling and validation of these links is discussed in the next subsection.

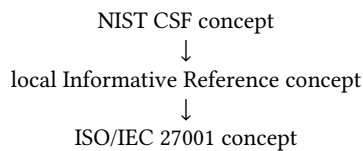
The final output of this step is the Turtle file `nist_csf2_taxonomy.ttl`. Turtle was selected because it is a readable RDF serialization and is supported by common RDF tools, SPARQL engines, SHACL validators, and SKOS browsers. The generated file contains

the CSF Core concept scheme, the Informative Reference concept scheme, all active Function, Category, and Subcategory concepts, multilingual labels and definitions, implementation examples, hierarchy links, local reference concepts, and external reference links.

3.4 Linking to ISO/IEC 27001

The taxonomy was designed to support cross-standard navigation between the NIST CSF 2.0 Core and ISO/IEC 27001 [1]. ISO/IEC 27001 was selected as the linking target because an existing SKOS taxonomy for ISO/IEC 27001 had already been developed in earlier student work on related topic [4]. Reusing this taxonomy made it possible to connect the generated NIST CSF taxonomy to an already machine-readable cybersecurity standard instead of recreating ISO/IEC 27001 manually.

The linking approach follows the reference structure already present in the NIST CSF. A NIST CSF concept is not linked directly to an ISO/IEC 27001 concept but to a local Informative Reference concept using `dcterms:references`, and then linked to the matching ISO/IEC 27001 concept. This creates the following linking pattern:



This design was chosen because a CSF Subcategory and an ISO/IEC 27001 clause are not necessarily equivalent concepts. A CSF Subcategory describes a cybersecurity outcome, while an ISO/IEC 27001 clause belongs to a different standard. Therefore, linking a NIST concept directly to an ISO concept using `skos:exactMatch` could incorrectly suggest that the two concepts have the same meaning. By placing the mapping on the local Informative Reference concept, the taxonomy preserves the original NIST reference relation while still enabling navigation to the corresponding ISO concept.

The implementation loads the existing ISO/IEC 27001 SKOS taxonomy as a separate RDF graph and creates lookup tables for ISO/IEC 27001 mandatory clauses and Annex A controls. These lookup tables are based on the `skos:notation` values of the ISO concepts, so mappings are created from explicit identifiers, such as clause numbers and control numbers, rather than from manual interpretation of similar labels or descriptions.

During RDF generation, each Informative Reference string is checked to determine whether it refers to ISO/IEC 27001:2022. The script handles two main types of ISO references: mandatory clauses and Annex A controls. References containing `Mandatory Clause` are matched against the ISO clause lookup table, while references containing `Annex A Controls` are matched against the ISO Annex A control lookup table. If a matching ISO concept is found, the local Informative Reference concept is connected to that ISO concept using `skos:exactMatch` [5].

The use of `skos:exactMatch` is limited to the relation between the local Informative Reference concept and the ISO taxonomy concept. This is important because the local reference concept represents the same referenced ISO clause or control as the ISO taxonomy concept. In contrast, the NIST CSF concept only references that external item and is therefore connected to the local reference concept

using `dcterms:references`. This distinction avoids treating NIST outcomes and ISO controls as equivalent.

The linking process also normalizes some ISO control identifiers to improve matching. For example, Annex A controls may appear with or without the `A.` prefix. The lookup therefore supports both forms so that references such as `A.5.1` and `5.1` can be matched to the same ISO control concept where appropriate. References that do not refer to ISO/IEC 27001:2022, or that do not contain a mandatory clause or Annex A control identifier, are not mapped to the ISO taxonomy and remain represented as local Informative Reference concepts.

3.5 Validation Approach

The generated taxonomy was validated in three stages, corresponding to the three sub-research questions. SRQ1 was evaluated through structural validation of the NIST CSF 2.0 taxonomy itself. SRQ2 was evaluated through competency questions translated into SPARQL queries. SRQ3 was evaluated through dedicated SPARQL checks for the ISO/IEC 27001 mapping links. This combination was used because valid RDF syntax alone does not show whether the taxonomy preserves the intended CSF hierarchy, supports practitioner queries, or enables correct cross-standard navigation.

For SRQ1, SHACL was used to validate the structure of the taxonomy [8]. The SHACL shapes check whether CSF concepts contain required properties such as `skos:notation`, `skos:prefLabel`, `skos:definition`, and `skos:inScheme`. They also check whether the Function–Category–Subcategory hierarchy is preserved and whether broader and narrower relations are used consistently. In addition to SHACL, structural SPARQL checks were used to inspect issues that are easy to report in tabular form, such as missing English labels, duplicate notations, and the presence of the reference model.

For SRQ2, the taxonomy was evaluated using competency questions. These are natural-language questions that define what the taxonomy should be able to answer. The competency questions were created in several steps. First, questions were derived from the structure of the NIST CSF 2.0 Core itself, including questions about Functions, Categories, Subcategories, definitions, hierarchy navigation, implementation examples, and Informative References. Second, additional questions were informed by publicly available practitioner-oriented material, such as courses, webinars, interviews, guidance pages, and examples discussing how the NIST CSF is used in practice. These sources helped identify common cybersecurity situations where users may want to retrieve relevant CSF outcomes, such as ransomware, leaked account data, supplier incidents, exposed cloud storage, or compromised credentials. Third, questions were added to test cross-standard navigation between NIST CSF outcomes and ISO/IEC 27001 concepts. This resulted in a set of questions that tests both basic taxonomy navigation and more practical retrieval scenarios.

The questions were grouped into categories covering CSF hierarchy navigation, definitions, implementation examples, Informative References, scenario-based practitioner retrieval, and ISO/IEC 27001 navigation. Each question was translated into an executable SPARQL query and run against the generated Turtle file [7]. The returned

results were then compared with the expected answers from the competency-question table. This comparison was used to check whether the taxonomy could provide the information required by each competency question.

For SRQ3, separate SPARQL checks were used to validate the ISO/IEC 27001 linking model. These checks verify whether ISO mapping links exist, whether mapping targets point to the expected ISO taxonomy namespace, whether mapping subjects are local Informative Reference concepts, and whether navigation works from NIST to ISO and from ISO back to NIST. This was necessary because the mapping model depends not only on the existence of `skos:exactMatch` triples, but also on those triples being attached to the correct kind of concept.

4 Results

4.1 Generated NIST CSF 2.0 SKOS Taxonomy

The generated taxonomy contains 35,561 RDF triples and represents the active NIST CSF 2.0 Core together with local Informative Reference concepts and selected ISO/IEC 27001 links. The result is not only a direct RDF conversion of the spreadsheet data, but a structured SKOS graph in which CSF concepts, references, external webpages, and ISO mappings can be queried together.

The taxonomy contains two SKOS concept schemes. The first concept scheme represents the NIST CSF 2.0 Core, while the second concept scheme represents the local Informative Reference concepts. The NIST CSF Core part of the taxonomy contains 134 active core concepts: 6 Functions, 22 Categories, and 106 Subcategories. The 6 Functions are modeled as top concepts of the Core concept scheme, while the Categories and Subcategories are connected through `skos:broader` and `skos:narrower`.

The distribution of Informative References provides more detail about the reference layer of the taxonomy. The most frequent sources are shown in Table 1. The largest groups of references come from the NICE Framework, NIST SP 800-53, CCMv4.0, PCI DSS, ISO/IEC 27001, SCF, and CRI Profile v2.0. This supports the decision to model Informative References as separate concepts, because the taxonomy can be queried not only by CSF outcome, but also by the external standards and guidance sources connected to them.

Table 1. Most frequent Informative Reference sources

Reference source	Links
NICE Framework	850
SP 800-53 Rev 5.2.0	746
SP 800-53 Rev 5.1.1	740
CCMv4.0	657
PCI DSS	551
ISO/IEC 27001	492
SCF	473
CRI Profile v2.0	433
SP 800-171 Rev 3	313
SP 800-37 Rev 2	217

The taxonomy also includes multilingual labels and definitions. The generated graph contains 1,605 `skos:prefLabel` literals and 1,605 `skos:definition` literals for the CSF Core concepts. These labels and definitions are represented with language tags, allowing the same concept URI to be reused across multiple languages.

Most language files provided labels and descriptions for all 134 core concepts, but a small number of translated values were missing in the source files. This explains why the total number of multilingual labels and definitions is slightly lower than the theoretical maximum.

Overall, the generated artifact preserves the main CSF Core hierarchy while extending it with RDF links for references, external webpages, multilingual access, and ISO/IEC 27001 mappings.

4.2 Structural Validation Results

The structural validation was performed using SHACL constraints and additional SPARQL quality checks. The SHACL report returned `Conforms: True`, meaning that no violations were found. This indicates that the generated taxonomy follows the expected SKOS structure.

The SHACL shapes checked whether core CSF concepts had the required labels, definitions, notations, and scheme membership. They also checked whether Functions, Categories, and Subcategories appeared in the correct hierarchy, whether `skos:broader` and `skos:narrower` were consistent, whether the hierarchy had no cycles, and whether ISO `skos:exactMatch` links were attached only to Informative Reference concepts.

The additional SPARQL checks also passed. These checks confirmed that no core concepts were missing English preferred labels, no duplicate notations were found within concept schemes, and the reference model was present. The reference-count query returned 6,332 `dcterms:references` triples, 2,015 Informative Reference concepts, and 90 `skos:exactMatch` links.

Table 2. Structural validation results

Check	Check
SHACL conformance	Core properties
CSF hierarchy	Relation consistency
No hierarchy cycles	Reference structure
ISO mapping placement	Missing English labels
Duplicate notations	Reference model

These results show that the generated RDF graph satisfies the expected structural requirements for SRQ1.

4.3 Competency Question Results

The second validation step checks whether the taxonomy could answer the competency questions defined for SRQ2. In total, 34 CQs were translated into SPARQL queries and run against the generated Turtle file. The questions were grouped into categories to show which parts of the taxonomy were being tested. Table 3 summarizes the number of questions in each category and how many were answered successfully.

The results show that all competency questions were answered by the taxonomy. The queries returned different types of results depending on the question category, this shows that the taxonomy supports more than simple hierarchy browsing and can be queried for practitioner questions too.

For example, CQ19 asked for the definition of the NIST CSF ID.RA-08 Subcategory. This question was translated into a SPARQL query that retrieves the notation, preferred label, and definition of the selected CSF concept.

Table 3. Competency question validation summary

Category	CQs	Ans.
Governance and risk	4	4
Identify outcomes	3	3
Protect outcomes	4	4
Detect/respond/recover	5	5
Structure and definitions	4	4
Scenario retrieval	6	6
ISO navigation	3	3
Practitioner retrieval	5	5
Total	34	34

Example CQ19 SPARQL query

```
SELECT DISTINCT ?notation ?label ?definition
WHERE {
  csf:ID-RA-08 skos:notation ?notation ;
  skos:prefLabel ?label ;
  skos:definition ?definition .
  FILTER(LANGMATCHES(LANG(?label), "en"))
  FILTER(LANGMATCHES(LANG(?definition), "en"))
}
```

The full list of competency questions, expected result types, SPARQL queries, and output references is included in Appendix A. Overall, the competency-question validation provides evidence for SRQ2, because it shows that the generated SKOS taxonomy can answer the intended query tasks using standard SPARQL queries.

4.4 ISO/IEC 27001 Mapping Results

Five dedicated SPARQL checks were used to validate whether the taxonomy supports navigation between NIST CSF 2.0 and the ISO/IEC 27001 SKOS taxonomy. This addresses SRQ3. The checks tested whether ISO mappings exist, whether all mapping targets point to the expected ISO/IEC 27001 taxonomy namespace, whether mappings start from Informative Reference concepts, and whether navigation works in both directions between NIST CSF and ISO/IEC 27001.

Table 4. ISO/IEC 27001 mapping validation results

Check	Purpose	Actual result
M01	ISO mappings are present	90 mappings
M02	ISO mapping targets use Ion's ISO taxonomy namespace	0 invalid rows
M03	ISO mappings start from Informative Reference concepts	0 invalid rows
M04	Navigation from NIST CSF concepts to ISO/IEC 27001 concepts works	50 rows returned
M05	Navigation from ISO/IEC 27001 concepts back to NIST CSF concepts works	50 rows returned

The results show that the mapping model is structurally consistent. M01 confirms that ISO/IEC 27001 mappings are present. M02 and M03 show that the mappings are attached to the correct type of concept and point to the expected ISO taxonomy namespace. M04 and M05 show that users can navigate from NIST CSF outcomes to related ISO/IEC 27001 concepts and from ISO/IEC 27001 concepts back to related NIST CSF outcomes. Therefore, the mapping validation provides evidence for SRQ3.

4.5 Browser Implementation

A web browser was also implemented as a supporting artifact for exploring the taxonomy without requiring users to write SPARQL queries [5–7]. The browser is generated as a static HTML page from the RDF/SKOS taxonomy and can be served locally after the

taxonomy build process. It loads both the NIST CSF 2.0 and the ISO/IEC 27001 SKOS taxonomies, allowing both to be inspected in one interface.

The browser also includes a graph view that visualizes relationships around a selected concept, including hierarchy links, reference links, and exact-match links to ISO/IEC 27001 concepts. This makes the taxonomy easier to inspect manually and demonstrates how the RDF/SKOS representation can be used in a practical interface. The browser was not used as a validation mechanism. Instead, it was implemented as a way to explore and use the generated data. The public GitHub Pages version of the browser and the source repository are listed in Appendix C. Example screenshots of the browser are included in Appendix B.

5 Conclusion

This research developed a validated, machine-readable SKOS taxonomy of the NIST Cybersecurity Framework (CSF) 2.0. The main output of the project is a Turtle-based RDF/SKOS representation of the NIST CSF 2.0 Core that preserves the framework structure and makes it possible to query, validate, browse, and link CSF concepts to related ISO/IEC 27001 concepts. The resulting taxonomy provides a semantic layer on top of the official NIST CSF material. It does not replace the official framework documentation, but makes the framework easier to use in machine-readable environments.

For SRQ1, this research identified and represented the main structural elements of the NIST CSF 2.0 Core. Functions, Categories, and Subcategories were modeled as SKOS concepts. Their identifiers were represented using `skos:notation`, labels using `skos:prefLabel`, and descriptions using `skos:definition`. The hierarchical structure of the framework was represented using `skos:broader` and `skos:narrower`, preserving the Function–Category–Subcategory structure of the original CSF Core. Selected Informative References were represented as local reference concepts and connected to CSF outcomes using `dcterms:references`, allowing external guidance and standards to be queried without treating them as equivalent to CSF outcomes.

For SRQ2, the taxonomy was evaluated through 34 competency questions translated into SPARQL queries. These questions tested whether the taxonomy could retrieve relevant Functions, Categories, Subcategories, definitions, Informative References, ISO/IEC 27001 links, and practitioner-oriented results. All competency questions were answered successfully. This shows that the taxonomy supports more than simple hierarchy browsing and can answer different types of query tasks, including structure navigation, definition retrieval, scenario-based retrieval, and cross-standard lookup.

For SRQ3, this research linked the NIST CSF 2.0 taxonomy to an existing ISO/IEC 27001 SKOS taxonomy. The links make it possible to navigate from NIST CSF outcomes to related ISO/IEC 27001 concepts, such as clauses and Annex A controls, where meaningful relationships exist. The mappings are intended to support navigation between related concepts. They do not claim that NIST CSF outcomes and ISO/IEC 27001 controls are fully equivalent, nor that satisfying one standard automatically demonstrates compliance with the other. Nevertheless, the mapping results show that the taxonomy can support cross-standard navigation and can serve as

a basis for further integration with other cybersecurity frameworks and standards.

A local browser was also implemented as a supporting artifact. The browser allows users to inspect the taxonomy, navigate the CSF hierarchy, view concept information, and explore graph relationships without writing SPARQL queries. This demonstrates how the generated RDF/SKOS data can be made more accessible to users who are not familiar with Semantic Web tools.

Future work could extend the taxonomy in several directions. One important extension would be to include NIST CSF Profiles and Tiers. This would allow practitioners to represent current and target cybersecurity states and use the taxonomy for assessment, prioritization, and improvement planning. Future work could also expand the mappings to additional standards and frameworks, such as NIST SP 800-53, CIS Controls, COBIT, or other ISO/IEC 27000-series standards. Another direction would be to model common cybersecurity scenarios more explicitly, for example by adding scenario tags or another linking mechanism that connects cases such as ransomware, credential compromise, cloud data exposure, or supplier breaches to relevant CSF outcomes.

Future work could also investigate whether standard RDF mapping languages such as R2RML or RML could be used instead of, or together with, the current Python-based transformation pipeline. The Python pipeline was useful for keeping the extraction and RDF generation steps explicit, but mapping languages could make the transformation process more reusable.

Another limitation is that the competency questions were not collected through practitioner interviews. Such interviews would likely have produced a stronger set of CQs. However, finding a sufficiently large group of suitable practitioners was outside the time and access for this project. For that reason, improving the competency questions through practitioner interviews or expert feedback is treated as future work.

Acknowledgments

I would like to thank Ítalo Oliveira and Dipti Sarmah for their guidance and assistance during this research. I would also like to express my thanks to Dr. T. Prince Sales for his feedback through the process.

References

- [1] National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST Cybersecurity White Paper 29, February 2024. <https://doi.org/10.6028/NIST.CSWP.29>
- [2] National Institute of Standards and Technology. *Introducing the NIST Cybersecurity Framework 2.0 Reference Tool*. Computer Security Resource Center, August 2023. <https://csrc.nist.gov/News/2023/just-released-nist-csf-2-0-reference-tool>
- [3] National Institute of Standards and Technology. *NIST Cybersecurity Framework 2.0 Reference Tool*. NIST Computer Security Resource Center, 2024.
- [4] I. Donos. *Building a Machine-Readable SKOS Taxonomy of ISO/IEC 27001:2022*. University of Twente, 2026.
- [5] A. Miles and S. Bechhofer. *SKOS Simple Knowledge Organization System Reference*. W3C Recommendation, 18 August 2009. <https://www.w3.org/TR/skos-reference/>
- [6] R. Cyganiak, D. Wood, and M. Lanthaler. *RDF 1.1 Concepts and Abstract Syntax*. W3C Recommendation, 25 February 2014. <https://www.w3.org/TR/rdf11-concepts/>
- [7] S. Harris and A. Seaborne. *SPARQL 1.1 Query Language*. W3C Recommendation, 21 March 2013. <https://www.w3.org/TR/sparql11-query/>
- [8] H. Knublauch and D. Kontokostas. *Shapes Constraint Language (SHACL)*. W3C Recommendation, 20 July 2017. <https://www.w3.org/TR/shacl/>
- [9] M. Grüninger and M. S. Fox. The role of competency questions in enterprise engineering. In *Benchmarking – Theory and Practice*, pp. 22–31. Springer, 1995. https://doi.org/10.1007/978-0-387-34847-6_3
- [10] S. Fenz, G. Goluch, A. Ekelhart, B. Riedl, and E. Weippl. Information security fortification by ontological mapping of the ISO/IEC 27001 standard. In *Proceedings of the 13th Pacific Rim International Symposium on Dependable Computing*, pp. 381–388. IEEE, 2007. <https://doi.org/10.1109/PRDC.2007.29>
- [11] S. Fenz and A. Ekelhart. Formalizing information security knowledge. In *Proceedings of the 4th International Symposium on Information, Computer, and Communications Security*, pp. 183–194. ACM, 2009. <https://doi.org/10.1145/1533057.1533084>
- [12] S. Fenz, S. Plieschnegger, and H. Hobel. Ontology-based information security compliance determination. *Information & Computer Security*, 24(5):552–567, 2016. <https://doi.org/10.1108/ICS-07-2015-0030>
- [13] I. Meriah and L. Ben Arfa Rabai. Comparative study of ontologies based ISO 27000 series security standards. *Procedia Computer Science*, 160:85–92, 2019. <https://doi.org/10.1016/j.procs.2019.09.447>
- [14] National Institute of Standards and Technology. *Cybersecurity and Privacy Reference Tool*. NIST Computer Security Resource Center. <https://csrc.nist.gov/projects/cprt>
- [15] N. Keller, S. Quinn, K. Scarfone, M. Smith, and V. Johnson. *National Online Informative References (OLIR) Program: Overview, Benefits, and Use*. NIST Interagency/Internal Report 8278 Revision 1, February 2024. <https://doi.org/10.6028/NIST.IR.8278r1>
- [16] N. Teodoro, L. Gonçalves, and C. Serrão. NIST CyberSecurity Framework Compliance: A Generic Model for Dynamic Assessment and Predictive Requirements. In *Proceedings of the 2015 IEEE Trustcom/BigDataSE/ISPA*, vol. 1, pp. 418–425. IEEE, 2015. <https://doi.org/10.1109/Trustcom.2015.402>
- [17] C. Onwubiko. CoCoA: An Ontology for Cybersecurity Operations Centre Analysis Process. In *Proceedings of the 2018 International Conference on Cyber Situational Awareness, Data Analytics and Assessment (Cyber SA)*. IEEE, 2018. <https://doi.org/10.1109/CyberSA.2018.8551486>
- [18] W. Wong, Z. Alomari, Y. Shao, and M. I. Satti. Knowledge Graph to Facilitate Cloud Security Compliance with NIST Cybersecurity Framework. In *Proceedings of the 2nd International Conference on Computer, Vision and Intelligent Technology (ICCVIT)*, pp. 1–6. IEEE, 2024. <https://doi.org/10.1109/ICCVIT63928.2024.10872451>
- [19] E. Koza. Semantic Analysis of ISO/IEC 27000 Standard Series and NIST Cybersecurity Framework to Outline Differences and Consistencies in the Context of Operational and Strategic Information Security. *Medicon Engineering Themes*, 2(3):26–39, 2022.
- [20] M. A. Adeler, Y. Morgan, and L. Benedicenti. *RiskOnto 1.0: An Ontology Driven Framework for Threat Modeling and Risk Reasoning Using the NIST Cybersecurity Framework*. SSRN preprint, 2025. https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6465624

A Competency Questions and Validation Results

This appendix summarizes the competency questions used to validate SRQ2. In these questions, the term *outcome* refers to a NIST CSF Function, Category, or Subcategory, depending on the query. The expected answer column gives a compact version of the answer that the SPARQL query should return.

Table 5. Competency question validation results

CQ	Question	Expected answer
Governance, Risk & Supply Chain Retrieval		
CQ01	Which CSF outcomes help an organization understand its mission, stakeholders, dependencies, and legal or contractual requirements?	GV.OC-01–GV.OC-05, including mission, stakeholders, legal requirements, critical dependencies, and dependent services.
CQ02	Which CSF outcomes help define cybersecurity risk objectives, risk appetite, and risk tolerance?	GV.RM-01–GV.RM-07, covering risk objectives, risk appetite, risk tolerance, enterprise risk management, communication, standardized risk methods, and strategic opportunities.
CQ03	Which CSF outcomes help define who is responsible and accountable for cybersecurity risk management?	GV.RR-01–GV.RR-04, covering leadership accountability, roles and responsibilities, resource allocation, and cybersecurity in human resources practices.
CQ04	Which CSF outcomes help manage cybersecurity risks from suppliers and third parties?	GV.SC-01–GV.SC-10, covering cybersecurity supply chain risk management strategy, responsibilities, integration, supplier prioritization, contractual requirements, planning, monitoring, and incident involvement.
Identify: Asset, Risk & Improvement Retrieval		
CQ05	Which CSF outcomes help identify and inventory hardware, software, services, systems, and data?	ID.AM-01, ID.AM-02, ID.AM-03, ID.AM-04, ID.AM-05, ID.AM-07, and ID.AM-08.
CQ06	Which CSF outcomes help assess vulnerabilities, threats, likelihood, and impact?	ID.RA-01–ID.RA-10, covering vulnerabilities, threat intelligence, internal and external threats, likelihood, impact, risk response, and supplier risk assessment.
CQ07	Which CSF outcomes help identify improvements after audits, assessments, incidents, or lessons learned?	ID.IM-01–ID.IM-04, covering improvements from evaluations, tests, exercises, operational processes, and incident response planning.
Protect: Access, Data & Platform Security Retrieval		
CQ08	Which CSF outcomes help manage identity, authentication, and access control?	PR.AA-01–PR.AA-06, covering identity management, credential proofing, authentication, identity assertions, access permissions, and physical access management.
CQ09	Which CSF outcomes help protect employees and users through cybersecurity awareness and training?	PR.AT-01 and PR.AT-02, covering general cybersecurity awareness and specialized role-based training.
CQ10	Which CSF outcomes help protect data confidentiality, integrity, and availability?	PR.DS-01, PR.DS-02, PR.DS-10, and PR.DS-11, covering data-at-rest, data-in-transit, data-in-use, and backups.
CQ11	Which CSF outcomes help protect systems through secure configuration, patching, backups, logging, and infrastructure resilience?	PR.PS, PR.PS-01–PR.PS-06, PR.IR, and PR.IR-01–PR.IR-04, covering platform security, configuration, maintenance, logging, unauthorized software prevention, secure software development, and infrastructure resilience.
Detect, Respond & Recover Operations		
CQ12	Which CSF outcomes help detect cybersecurity attacks, anomalies, and suspicious activity?	DE.CM-01, DE.CM-02, DE.CM-03, DE.CM-06, and DE.CM-09, covering network, physical, personnel, service provider, hardware, software, and data monitoring.
CQ13	Which CSF outcomes help manage and execute incident response activities?	RS.MA-01–RS.MA-05, covering incident response execution, report triage, categorization, escalation, and recovery criteria.
CQ14	Which CSF outcomes help communicate and report cybersecurity incidents?	RS.CO-02 and RS.CO-03, covering notification of stakeholders and sharing incident information with designated parties.
CQ15	Which CSF outcomes help contain, eradicate, or mitigate cybersecurity incidents?	RS.MI-01 and RS.MI-02, covering incident containment and eradication.
CQ16	Which CSF outcomes help communicate recovery status after an incident?	RC.CO-03 and RC.CO-04, covering recovery progress communication and public recovery updates.
NIST CSF Structure, Definitions & Navigation		
CQ17	Which NIST CSF Function covers establishing cybersecurity policy and oversight over cybersecurity risk management?	GV – GOVERN, together with GV.PO – Policy and GV.OV – Oversight.
CQ18	What is the definition of the NIST CSF GV.OV Oversight Category?	GV.OV definition: Results of organization-wide cybersecurity risk management activities and performance are used to inform, improve, and adjust the risk management strategy.
CQ19	What is the definition of the NIST CSF ID.RA-08 Subcategory?	ID.RA-08 definition: Processes for receiving, analyzing, and responding to vulnerability disclosures are established.
CQ20	Which NIST CSF Category does RS.AN-06 belong to, and what is its definition?	RS.AN-06 belongs to RS.AN – Incident Analysis. RS.AN-06 definition: Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved.
Scenario-Based Practitioner Retrieval		
CQ21	Which NIST CSF outcomes and references are relevant when responding to a leaked accounts database containing user account information?	Relevant outcomes include ID.AM-07, ID.RA-04, DE.AE-04, DE.AE-08, RS.AN-03, RS.AN-07, RS.CO-02, RS.MI-01, RC.RP-02, and ID.IM-04, returned with Informative References and external links.
CQ22	Which NIST CSF outcomes and references are relevant when employee credentials are suspected to be compromised?	Relevant outcomes include PR.AA-01, PR.AA-03, PR.AA-05, DE.CM-03, DE.AE-02, RS.AN-03, RS.MI-01, RS.CO-02, and ID.IM-04, returned with Informative References and external links.
CQ23	Which NIST CSF outcomes and references are relevant when ransomware affects critical business systems?	Relevant outcomes include ID.AM-05, PR.DS-11, PR.PS-01, PR.PS-04, PR.IR-03, DE.CM-09, RS.MA-01, RS.MI-01, RS.MI-02, RC.RP-01, RC.RP-03, and RC.CO-03, returned with Informative References and external links.
CQ24	Which NIST CSF outcomes and references are relevant when a third-party supplier suffers a security breach?	Relevant outcomes include GV.SC-04, GV.SC-07, GV.SC-08, GV.OC-05, ID.RA-10, DE.AE-04, RS.CO-02, RS.MI-01, and ID.IM-02, returned with Informative References and external links.
CQ25	Which NIST CSF Subcategories are relevant when an organization discovers unpatched internet-facing systems?	ID.AM-01, ID.AM-02, ID.RA-01, ID.RA-05, ID.RA-06, PR.PS-02, DE.CM-09, RS.MI-01, and ID.IM-03.

CQ	Question	Expected answer
CQ26	Which NIST CSF Subcategories are relevant when a cloud storage bucket containing sensitive data is accidentally exposed to the internet?	ID.AM-04, ID.AM-07, PR.DS-01, PR.DS-02, PR.AA-05, DE.CM-09, DE.AE-04, DE.AE-08, RS.MI-01, and RS.CO-02.
Cross-Standard Mapping & ISO/IEC 27001 Navigation		
CQ27	Which ISO/IEC 27001 controls are related to NIST CSF access-control outcomes?	PR.AA outcomes link to ISO/IEC 27001 controls including A.5.1, A.5.14, A.5.15, A.5.16, A.5.17, A.5.18, A.5.3, A.7.1, A.7.2, A.7.3, A.7.4, A.7.12, A.8.2, A.8.3, A.8.5, and A.8.18.
CQ28	Which ISO/IEC 27001 controls are linked to the NIST CSF PR.PS-04 Subcategory for log records and continuous monitoring?	PR.PS-04 links to ISO/IEC 27001 A.8.15 – Logging and A.8.17 – Clock synchronization.
CQ29	Which NIST CSF Subcategories are linked to ISO/IEC 27001 control A.8.13 Information backup?	NIST CSF concepts linked to ISO/IEC 27001 A.8.13 include PR.DS-11, RC.RP-03, and RC.RP-06.
Practitioner-Focused Control & Responsibility Retrieval		
CQ30	Who is responsible for cybersecurity risk management and supplier security responsibilities?	GV.RR-01, GV.RR-02, and GV.SC-02, covering leadership accountability, cybersecurity roles and responsibilities, and supplier/customer/partner responsibilities.
CQ31	How can user accounts and credentials be protected against unauthorized access?	PR.AA-01, PR.AA-02, PR.AA-03, PR.AA-04, PR.AA-05, and DE.CM-03, covering identities, credentials, authentication, authorization, access permissions, and monitoring.
CQ32	Which CSF outcomes help ensure backups are available and safe to use after an incident?	PR.DS-11, RC.RP-03, and RC.RP-05, covering backup creation, backup integrity verification, and restored asset verification.
CQ33	Which CSF outcomes help monitor supplier or external service provider cybersecurity activities?	GV.SC-07, GV.SC-09, and DE.CM-06, covering supplier risk monitoring, supply chain security performance, and external service provider monitoring.
CQ34	Which CSF subcategories help decide whether an adverse event should become a declared incident and be escalated?	DE.AE-08, RS.MA-02, RS.MA-03, and RS.MA-04, covering incident declaration, triage, categorization, prioritization, and escalation.

B Browser Interface Screenshots

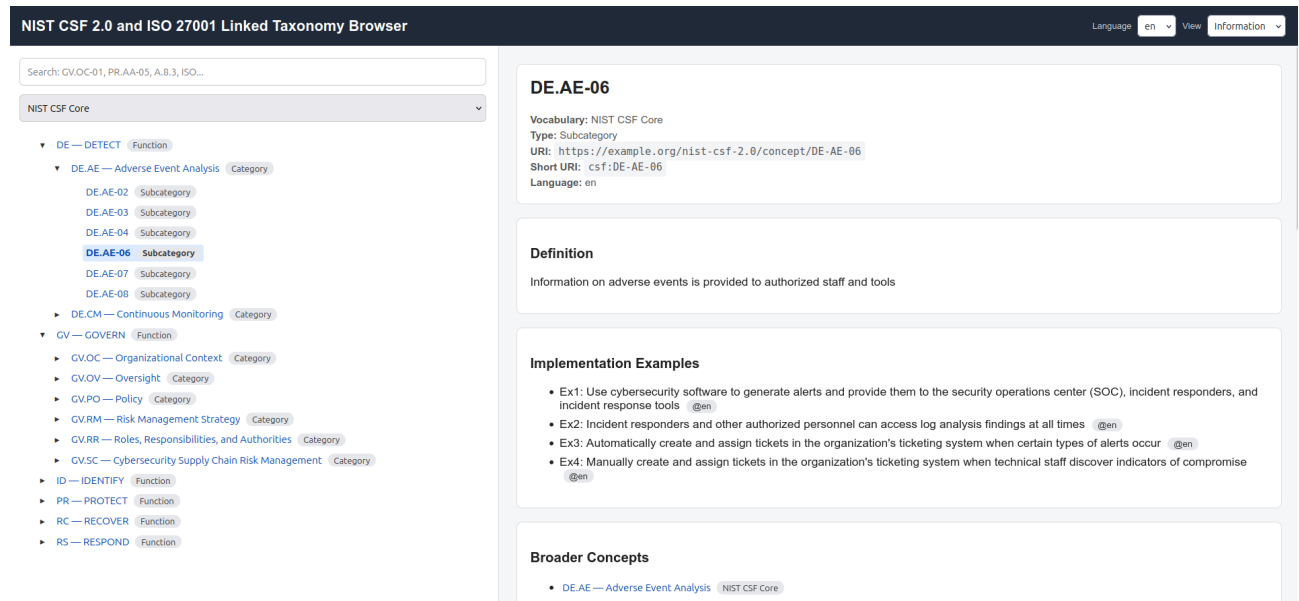


Fig. 2. Browser information view showing the selected NIST CSF Subcategory DE .AE-06, including its definition, implementation examples, and broader concept links.

C Artifact Availability

The source code, generated taxonomy files, validation queries, validation results, and browser implementation are available in the project repository:

- Project repository: <https://github.com/georgeturca/nistcsf2.0-skos-taxonomy>
- Public browser: <https://georgeturca.github.io/nistcsf2.0-skos-taxonomy/>

The GitHub Pages browser provides a public interface for exploring the generated NIST CSF 2.0 SKOS taxonomy and its links to ISO/IEC 27001 concepts.

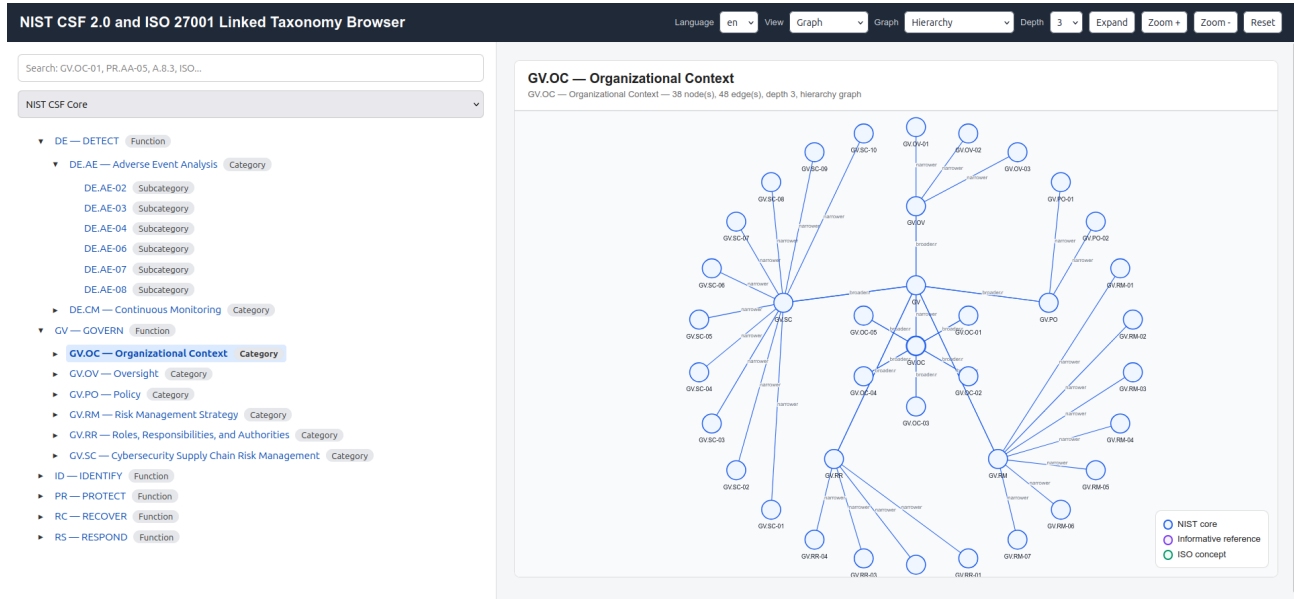


Fig. 3. Browser graph view showing the hierarchy around the NIST CSF Category GV.OC Organizational Context.

D AI Statement

During the preparation of this work, I used ChatGPT and Grammarly to check grammar, improve sentence clarity and academic language. I did not use these tools to independently generate the thesis text. All text included in this paper was reviewed, edited, and approved by me.

I also used Claude Opus to support the technical implementation of the project. This included help with finding bugs in the code, improving parts of the implementation, converting competency questions into executable SPARQL queries, and supporting the development of the web browser. In addition, I used Deep Research to help identify possible external URLs for Informative References. These external links were treated as supporting enrichment and were checked before being included in the generated taxonomy.

After using these tools, I reviewed and edited the outputs where necessary and take full responsibility for the final content.